



# Reciklaža.rs

Tehnička Dokumentacija Projekta

|            |                             |
|------------|-----------------------------|
| Verzija:   | 1.0                         |
| Datum:     | Jul 2026.                   |
| Platforma: | Web aplikacija              |
| Vlasnik:   | PORT 22 Mihailo Đorđević PR |
| PIB:       | 111988991                   |
| MB:        | 65790777                    |

POVJERLJIVO — INTERNA DOKUMENTACIJA

# Sadržaj

---

## 1. Pregled Projekta

- 1.1 Namena i opis
- 1.2 Tipovi korisnika
- 1.3 Ključne funkcionalnosti

## 2. Arhitektura Sistema

- 2.1 Tehnološki stek
- 2.2 Infrastruktura
- 2.3 Dijagram arhitekture

## 3. Struktura Projekta

## 4. Baza Podataka

- 4.1 Modeli (tabele)
- 4.2 Relacije između tabela

## 5. Autentikacija i Autorizacija

- 5.1 Tok registracije
- 5.2 Tok prijave
- 5.3 Uloge korisnika

## 6. API Dokumentacija

- 6.1 Autentikacija
- 6.2 Oglasi
- 6.3 Poruke
- 6.4 Korisnici
- 6.5 Admin

## 7. Frontend Stranice

## 8. Email Sistem

## 9. Upload Fajlova

## 10. Admin Panel

## 11. Bezbednost

## 12. Deployment i Infrastruktura

## 13. Konfiguracija Okruženja

## 14. Lokalni Razvoj

# 1. Pregled Projekta

---

## 1.1 Namena i opis

**Reciklaža.rs** je B2B web platforma za kupovinu i prodaju otpada u Srbiji. Platforma omogućava kompanijama i preduzetnicima da objavljuju oglase za otpad koji žele da prodaju ili predaju na reciklažu, kao i da pronalaze sakupljače otpada u svojoj blizini.

Sva komunikacija između korisnika odvija se isključivo unutar platforme putem ugrađenog sistema za poruke — telefonski brojevi i email adrese korisnika nisu javno vidljivi, čime se obezbeđuje privatnost i bezbednost podataka.

Platforma je vlasništvo preduzetnika **PORT 22 Mihailo Đorđević PR** (PIB: 111988991, MB: 65790777) koji deluje isključivo kao posrednik — ne poseduje otpad, ne naplaćuje proviziju i ne učestvuje u transakcijama između korisnika.

## 1.2 Tipovi korisnika



### Generator otpada

- Firme koje proizvode otpad
- Mogu postavljati oglase
- Dodaju slike oglasa
- Komunikacija sa sakupljačima



### Sakupljač otpada

- Firme koje sakupljaju/recikliraju otpad
- Pregledaju oglase i kontaktiraju
- Ne mogu postavljati oglase
- Komunikacija sa generatorima



### Administrator

- Odobrava/odbija registracije novih korisnika
- Pregledava i modifikuje sve korisnike i oglase
- Kreira korisnike i oglase u ime firmi
- Šalje broadcast poruke svim korisnicima
- Pristup admin panelu na `/admin`

## 1.3 Ključne funkcionalnosti

| Funkcionalnost            | Opis                                                                                                                                | Status         |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------|----------------|
| Registracija sa dozvolama | Višekoračna registracija (tip → firma → upload dozvola → email/lozinka), verifikacija emaila i odobrenje od strane admina           | IMPLEMENTIRANO |
| Oglasi za otpad           | CRUD oglasa sa slikama, indeksnim brojem otpada, klasifikacijom, lokacijom, cenom. Filtri po kategoriji, opštini, tipu otpada       | IMPLEMENTIRANO |
| Sistem poruka             | Real-time komunikacija između korisnika putem polling mehanizma (5s interval). Inbox, nepročitani badge, direktne poruke sa profila | IMPLEMENTIRANO |
| Email verifikacija        | 6-cifreni verifikacioni kod, važi 15 minuta, mogućnost ponovnog slanja                                                              | IMPLEMENTIRANO |
| Zaboravljena lozinka      | Reset putem 6-cifrenog koda na email, važi 15 minuta                                                                                | IMPLEMENTIRANO |
| Admin panel               | Upravljanje korisnicima, oglasima, broadcast poruke, obaveštenja o novim registracijama i oglasima                                  | IMPLEMENTIRANO |
| Javni profili             | Profil firme sa listom oglasa, dugme za direktnu poruku                                                                             | IMPLEMENTIRANO |
| Sigurnost                 | Rate limiting, input sanitizacija, bcrypt hashovanje lozinki, middleware zaštita ruta                                               | IMPLEMENTIRANO |

## 2. Arhitektura Sistema

### 2.1 Tehnološki stek

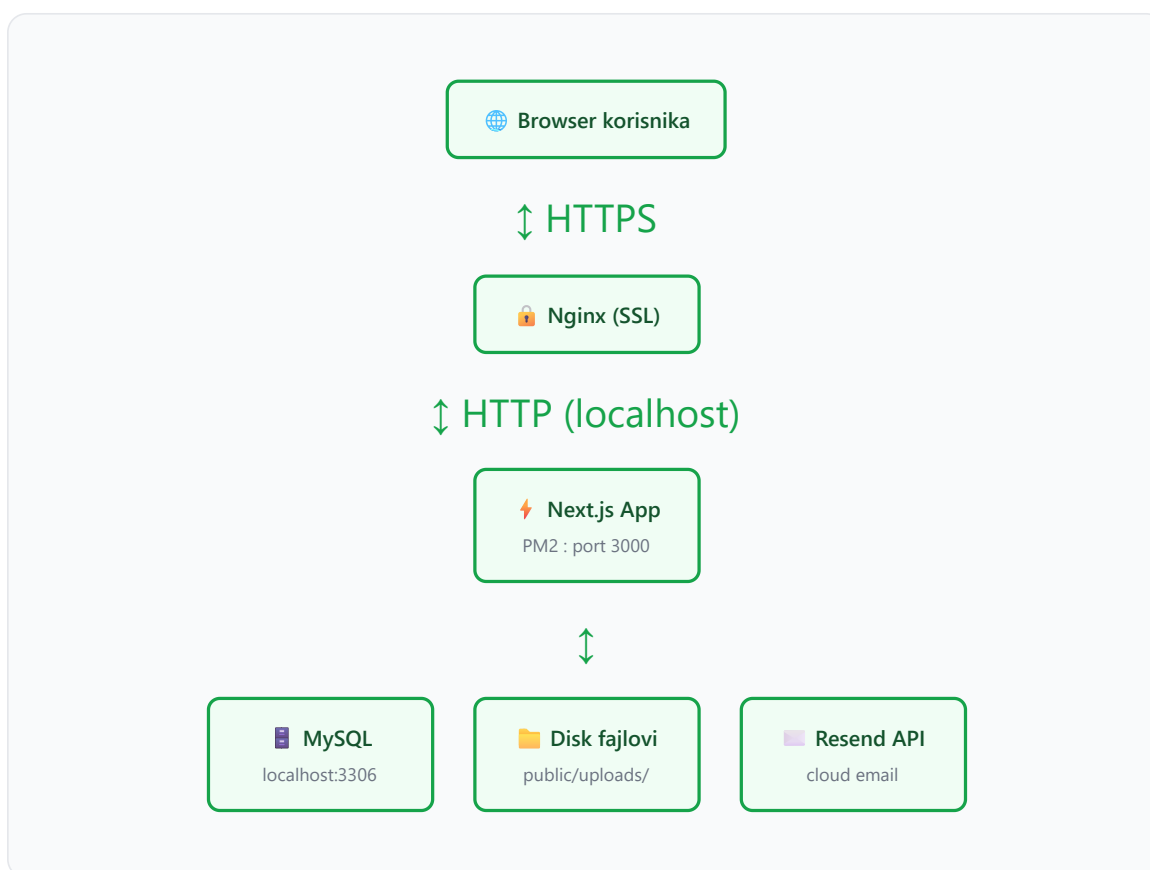
| Sloj            | Tehnologija          | Verzija  | Napomena                                                   |
|-----------------|----------------------|----------|------------------------------------------------------------|
| Frontend        | Next.js (App Router) | 16.x     | React Server Components + Client Components                |
| Backend         | Next.js API Routes   | 16.x     | Serverless funkcije unutar istog projekta                  |
| Jezik           | TypeScript           | 5.x      | Strogo tipizovan kod                                       |
| Baza podataka   | MySQL                | 8.0      | MariaDB kompatibilno                                       |
| ORM             | Prisma               | 5.22     | Type-safe upiti, migracije                                 |
| Autentikacija   | NextAuth.js v5       | 5.0-beta | JWT strategija, Credentials provider                       |
| Stilizovanje    | Tailwind CSS         | 4.x      | Utility-first CSS                                          |
| Ikone           | Lucide React         | 1.x      | SVG ikone                                                  |
| Validacija      | Zod                  | 4.x      | Schema validacija na klijentu i serveru                    |
| Email           | Resend               | latest   | Transakcioni emailovi sa DKIM/SPF                          |
| Upload fajlova  | Node.js fs           | —        | Lokalni disk na VPS-u, folder <code>public/uploads/</code> |
| Process manager | PM2                  | 7.x      | Auto-restart, boot startup                                 |
| Web server      | Nginx                | 1.18     | Reverse proxy, SSL terminacija                             |
| SSL             | Let's Encrypt        | —        | Besplatan, auto-renew putem Certbot-a                      |
| VPS             | Hostinger KVM        | —        | Ubuntu 22.04 LTS                                           |

### 2.2 Infrastruktura

**Hosting:** Sve komponente sistema (Next.js app, MySQL baza, fajlovi) nalaze se na jednom VPS serveru na IP adresi `152.239.119.45` (Hostinger, lokacija: EU). Ovo je namerna odluka radi predvidive i fiksne mesečne cene.

| Komponenta          | Lokacija                                                | Detalji                                                                             |
|---------------------|---------------------------------------------------------|-------------------------------------------------------------------------------------|
| Next.js aplikacija  | VPS: <code>/var/www/reciklaza-rs/</code>                | Pokreće se kao PM2 proces, port 3000                                                |
| MySQL baza          | VPS: localhost:3306                                     | Baza: <code>reciklaza</code> , korisnik: <code>reciklaza_app</code>                 |
| Uploadovani fajlovi | VPS: <code>/var/www/reciklaza-rs/public/uploads/</code> | Dozvole: <code>permits/{userId}/</code> , Slike: <code>listings/{listingId}/</code> |
| Nginx               | VPS: port 80/443                                        | Reverse proxy → localhost:3000                                                      |
| SSL sertifikat      | VPS: <code>/etc/letsencrypt/</code>                     | Let's Encrypt, auto-renew, ističe svakih 90 dana                                    |
| Domen               | Loopia DNS                                              | reciklaza.rs → 152.239.119.45                                                       |
| Email slanje        | Resend (cloud)                                          | API poziv ka Resend servisu                                                         |

## 2.3 Dijagram arhitekture



## 3. Struktura Projekta

```
reciklaža-rs/
├── prisma/
│   ├── schema.prisma      # Definicija baze podataka
│   ├── seed.ts            # Inicijalni podaci (test korisnici, admin)
│   └── migrations/        # Istorija migracija baze
├── public/
│   ├── uploads/
│   │   ├── permits/{userId}/ # Uploadovane dozvole korisnika
│   │   └── listings/{id}/    # Slike oglasa
│   └── favicon.svg
├── src/
│   ├── app/
│   │   ├── (auth)/          # Stranice bez navbar-a (prijava, registracija itd.)
│   │   │   ├── prijava/
│   │   │   ├── registracija/
│   │   │   ├── verifikacija-emaila/
│   │   │   ├── cekanje-odobrenja/
│   │   │   ├── zaboravljena-lozinka/
│   │   │   └── resetuj-lozinku/
│   │   ├── admin/           # Admin panel (zaštićeno, samo isAdmin)
│   │   │   ├── page.tsx      # Dashboard
│   │   │   ├── korisnici/    # Upravljanje korisnicima
│   │   │   ├── oglasi/       # Upravljanje oglasima
│   │   │   ├── obavestenja/  # Admin obavještenja
│   │   │   └── poruka-svima/  # Broadcast poruke
│   │   ├── api/             # REST API endpoints
│   │   │   ├── admin/        # Admin-only API rute
│   │   │   ├── auth/         # NextAuth handler
│   │   │   ├── conversations/ # Konverzacije
│   │   │   ├── forgot-password/
│   │   │   ├── listings/     # Oglasi CRUD
│   │   │   ├── messages/     # Poruke (polling)
│   │   │   ├── profile/      # Profili korisnika
│   │   │   ├── register/     # Registracija
│   │   │   ├── upload/       # Upload slika oglasa
│   │   │   ├── users/        # Lista korisnika
│   │   │   └── verify-email/  # Email verifikacija
│   │   ├── oglasi/          # Stranice oglasa
│   │   ├── korisnici/       # Lista korisnika
│   │   ├── poruke/          # Poruke
│   │   ├── profil/[id]/     # Javni profil
│   │   ├── podesavanja/     # Podešavanja naloga
│   │   ├── politika-privatnosti/
│   │   ├── uslovi-koriscenja/
│   │   ├── layout.tsx       # Root layout (SessionProvider)
│   │   ├── page.tsx         # Početna stranica
│   │   └── globals.css      # Globalni stilovi
│   ├── components/
│   │   ├── layout/          # Navbar, Footer
│   │   ├── listings/        # ListingCard, ListingFilters, ListingForm, ImageUploader
│   │   └── ui/              # Button, Input, Card, Badge, Avatar, Select, Spinner itd.
│   └── lib/
│       ├── auth.ts          # NextAuth konfiguracija
│       ├── email.ts         # Resend email funkcije
│       ├── prisma.ts        # Prisma singleton klijent
│       └── rate-limit.ts     # In-memory rate limiting
```

```
| | | constants/      # waste-categories, serbian-cities, units
| | | | utils/        # format, sanitize, upload helpers
| | | | | validations/  # Zod šeme (listing, auth, message)
| | |
| | | | middleware.ts    # Auth zaštita ruta (NextAuth authorized callback)
| | | | | types/
| | | | | | next-auth.d.ts  # Proširenje NextAuth tipova
| | |
| | | | .env            # Lokalne env varijable (NIJE u git-u)
| | | | | .env.example   # Primer env varijabli (U git-u)
| | | | | next.config.ts  # Next.js konfiguracija
| | | | | prisma.config.ts # Prisma konfiguracija
| | | | | package.json
| | | | | | tsconfig.json
```

# 4. Baza Podataka

ORM: **Prisma v5** — sve izmene šeme se rade u fajlu `prisma/schema.prisma`, a primenjuju komandom `npx prisma db push` (development) ili `npx prisma migrate deploy` (produkcija).

## 4.1 Modeli (tabele)

### User — Korisnici

| Kolona                     | Tip             | Opis                                          |
|----------------------------|-----------------|-----------------------------------------------|
| <code>id</code>            | String (cuid)   | Jedinstveni identifikator                     |
| <code>email</code>         | String (unique) | Email adresa                                  |
| <code>passwordHash</code>  | String          | bcrypt hash lozinke (salt rounds: 12)         |
| <code>companyName</code>   | String          | Naziv firme                                   |
| <code>pib</code>           | String (unique) | Poreski identifikacioni broj (9 cifara)       |
| <code>address</code>       | String          | Adresa sedišta                                |
| <code>city</code>          | String          | Grad (interno, ne prikazuje se korisnicima)   |
| <code>contactPerson</code> | String          | Kontakt osoba                                 |
| <code>phone</code>         | String?         | Telefon (opciono, NIKAD javno vidljiv)        |
| <code>userType</code>      | Enum            | GENERATOR ili COLLECTOR                       |
| <code>avatarUrl</code>     | String?         | URL profilne slike (nije implementirano)      |
| <code>bio</code>           | Text?           | Kratki opis firme                             |
| <code>emailVerified</code> | Boolean         | Da li je email verifikovan (default: false)   |
| <code>verified</code>      | Boolean         | Da li je admin odobrio nalog (default: false) |
| <code>isAdmin</code>       | Boolean         | Admin privilegija (default: false)            |
| <code>createdAt</code>     | DateTime        | Datum registracije                            |
| <code>updatedAt</code>     | DateTime        | Datum poslednje izmene                        |

## Permit — Dozvole

| Kolona                     | Tip           | Opis                                         |
|----------------------------|---------------|----------------------------------------------|
| <code>id</code>            | String (cuid) | Jedinstveni identifikator                    |
| <code>userId</code>        | String (FK)   | Vlasnik dozvole                              |
| <code>fileUrl</code>       | String        | Putanja fajla (PDF ili slika)                |
| <code>fileName</code>      | String        | Originalno ime fajla                         |
| <code>permitType</code>    | String        | collection / storage / transport / treatment |
| <code>status</code>        | Enum          | PENDING / APPROVED / REJECTED                |
| <code>reviewerNotes</code> | Text?         | Napomene admina                              |
| <code>uploadedAt</code>    | DateTime      | Datum uploada                                |
| <code>reviewedAt</code>    | DateTime?     | Datum pregleda                               |

## Listing — Oglasi

| Kolona                        | Tip           | Opis                                          |
|-------------------------------|---------------|-----------------------------------------------|
| <code>id</code>               | String (cuid) | Jedinstveni identifikator                     |
| <code>userId</code>           | String (FK)   | Autor oglasa (samo GENERATOR)                 |
| <code>title</code>            | String        | Naslov oglasa                                 |
| <code>description</code>      | Text          | Opis otpada                                   |
| <code>wasteIndexNumber</code> | String        | EU indeksni broj otpada (format: "XX XX XX")  |
| <code>wasteCategory</code>    | String        | Kategorija (npr. "metali", "nemetali")        |
| <code>wasteSubcategory</code> | String?       | Podkategorija (npr. "bakar", "plastika")      |
| <code>isHazardous</code>      | Boolean       | Da li je opasan otpad                         |
| <code>quantity</code>         | Decimal(12,2) | Količina                                      |
| <code>unit</code>             | String        | Jedinica mere: kg / tona / m3 / komad / litar |
| <code>pricePerUnit</code>     | Decimal?      | Cena (null = po dogovoru)                     |
| <code>currency</code>         | String        | Valuta (default: RSD)                         |
| <code>municipality</code>     | String        | Opština                                       |
| <code>address</code>          | String?       | Adresa (opciono)                              |
| <code>status</code>           | Enum          | ACTIVE / PAUSED / SOLD / EXPIRED              |
| <code>viewsCount</code>       | Int           | Broj pregleda                                 |
| <code>createdAt</code>        | DateTime      | Datum kreiranja                               |

## Ostali modeli

| Model                          | Opis                                                   | Ključna polja                                                    |
|--------------------------------|--------------------------------------------------------|------------------------------------------------------------------|
| <code>ListingImage</code>      | Slike vezane za oglas (max 8)                          | listingId, imageUrl, displayOrder                                |
| <code>Conversation</code>      | Razgovor između dva korisnika (opciono vezan za oglas) | listingId?, participant1Id, participant2Id, lastMessageAt        |
| <code>Message</code>           | Individualna poruka u razgovoru                        | conversationId, senderId, content, read                          |
| <code>VerificationCode</code>  | Kodovi za email verifikaciju i reset lozinke           | email, code, type (EMAIL_VERIFY/PASSWORD_RESET), expiresAt, used |
| <code>AdminNotification</code> | Obaveštenja za admina (nova registracija, novi oglas)  | type, title, message, data (JSON), read                          |

## 4.2 Relacije između tabela

```
User — Permit (1:N, onDelete: Cascade)
User — Listing (1:N, onDelete: Cascade)
User — Message (1:N, onDelete: Cascade)
User — Conversation (kao participant1 ili participant2, 1:N, onDelete: Cascade)

Listing — ListingImage (1:N, onDelete: Cascade)
Listing — Conversation (1:N, onDelete: Cascade)

Conversation — Message (1:N, onDelete: Cascade)

UNIQUE constraint: Conversation(listingId, participant1Id, participant2Id)
→ Sprečava dupliranje konverzacija za isti oglas i isti par korisnika
```

## 5. Autentikacija i Autorizacija

Koristi se **NextAuth.js v5** sa Credentials providerom i JWT strategijom. JWT token se čuva u HTTP-only cookie-ju, bez potrebe za tabelom sesija u bazi.

### 5.1 Tok registracije

```
Korak 1: Izbor tipa → GENERATOR ili COLLECTOR
↓
Korak 2: Unos podataka firme → naziv, PIB, adresa, opština, kontakt osoba, telefon
↓
Korak 3: Upload dozvola → minimum 1 fajl (PDF/JPG/PNG, max 10MB)
    → Fajlovi se čuvaju na: public/uploads/permits/{userId}/
↓
Korak 4: Email i lozinka → minimum 8 karaktera
↓
POST /api/register:
- Validacija PIB-a (9 cifara)
- Provera duplikata (email, PIB)
- bcrypt hashovanje lozinke (salt rounds: 12)
- Kreiranje User-a (emailVerified: false, verified: false)
- Čuvanje dozvola u Permit tabeli
- Generisanje 6-cifrenog koda, slanje na email putem Resend-a
- Kreiranje AdminNotification za admina
↓
/verifikacija-emaila → korisnik unosi 6-cifreni kod (važi 15 min)
↓
POST /api/verify-email → emailVerified: true
↓
/cekanje-odobrenja → korisnik čeka admin odobrenje
↓
Admin odobrava u /admin/korisnici → verified: true
    → šalje se email obaveštenje korisniku da je nalog odobren
↓
Korisnik se može prijaviti
```

### 5.2 Tok prijave

```
POST /api/auth/callback/credentials
↓
Provete u authorize() funkciji (src/lib/auth.ts):
1. Nalazi korisnika po emailu
2. bcrypt.compare(password, passwordHash)
3. if (!emailVerified) → throw Error('EMAIL_NOT_VERIFIED')
4. if (!verified && !isAdmin) → throw Error('NOT_APPROVED')
5. Uspešno → JWT token sadrži: id, email, userType, companyName, verified, isAdmin
↓
JWT token → HTTP-only cookie (SameSite=Lax)
↓
Middleware (src/middleware.ts) proverava JWT na svakom zahtevu
```

## 5.3 Uloge korisnika

| Uloga     | Uslov                             | Dozvoljene akcije                               |
|-----------|-----------------------------------|-------------------------------------------------|
| GOST      | Neprijavljen korisnik             | Samo: /prijava, /registracija, početna stranica |
| GENERATOR | userType=GENERATOR, verified=true | Sve + postavljanje oglasa                       |
| SAKUPLJAČ | userType=COLLECTOR, verified=true | Pregled oglasa, poruke, profili (bez oglasa)    |
| ADMIN     | isAdmin=true                      | Sve + /admin panel                              |

**Zaštita ruta:** Middleware u `src/middleware.ts` automatski preusmerava neprijavljene korisnike na `/prijava` za sve rute osim javnih (`/`, `/prijava`, `/registracija` i auth stranice). Admin rute (`/admin/*`) su zaštićene dodatnom proverom `isAdmin` flaga.

## 6. API Dokumentacija

Svi API endpoint-i nalaze se pod `/api/` prefiksom. Autorizovani endpoint-i zahtevaju važeću NextAuth sesiju u cookie-ju. Svi endpoint-i vraćaju JSON.

### 6.1 Autentikacija

| Metod | Endpoint                                    | Opis                                                                         | Auth |
|-------|---------------------------------------------|------------------------------------------------------------------------------|------|
| POST  | <code>/api/register</code>                  | Registracija novog korisnika (multipart/form-data, uključuje upload dozvola) | Ne   |
| POST  | <code>/api/verify-email</code>              | Verifikacija emaila 6-cifrenim kodom                                         | Ne   |
| PUT   | <code>/api/verify-email</code>              | Ponovo pošalji verifikacioni kod                                             | Ne   |
| POST  | <code>/api/forgot-password</code>           | Pošalji kod za reset lozinke                                                 | Ne   |
| PUT   | <code>/api/forgot-password</code>           | Reset lozinke sa kodom                                                       | Ne   |
| POST  | <code>/api/auth/callback/credentials</code> | NextAuth prijava (email + lozinka)                                           | Ne   |
| POST  | <code>/api/auth/signout</code>              | Odjava                                                                       | Da   |

### 6.2 Oglasi

| Metod  | Endpoint                        | Opis                                                                                             | Auth |
|--------|---------------------------------|--------------------------------------------------------------------------------------------------|------|
| GET    | <code>/api/listings</code>      | Lista oglasa. Query params: category, subcategory, municipality, hazardous, search, userId, page | Da   |
| POST   | <code>/api/listings</code>      | Kreiranje novog oglasa (samo GENERATOR)                                                          | Da   |
| GET    | <code>/api/listings/[id]</code> | Detalji jednog oglasa (uvećava viewsCount)                                                       | Da   |
| PUT    | <code>/api/listings/[id]</code> | Izmena oglasa (samo vlasnik)                                                                     | Da   |
| DELETE | <code>/api/listings/[id]</code> | Brisanje oglasa (samo vlasnik)                                                                   | Da   |
| POST   | <code>/api/upload</code>        | Upload slika za oglas (multipart, max 8 slika, 5MB po slici)                                     | Da   |

## 6.3 Poruke i konverzacije

| Metod | Endpoint                                 | Opis                                                                                   | Auth |
|-------|------------------------------------------|----------------------------------------------------------------------------------------|------|
| GET   | /api/conversations                       | Lista svih konverzacija prijavljenog korisnika sa brojem nepročitanih                  | Da   |
| POST  | /api/conversations                       | Kreiranje/pronalazak konverzacije (telo: {listingId?, otherUserId})                    | Da   |
| GET   | /api/messages?<br>conversationId=&after= | Poruke konverzacije (after param za polling novih). Automatski označava kao pročitane. | Da   |
| POST  | /api/messages                            | Slanje poruke (telo: {conversationId, content})                                        | Da   |

## 6.4 Korisnici i profili

| Metod | Endpoint                 | Opis                                                                   | Auth            |
|-------|--------------------------|------------------------------------------------------------------------|-----------------|
| GET   | /api/users               | Lista svih korisnika (bez sopstvenog). Filteri: city, userType, search | Da              |
| GET   | /api/profile/[id]        | Javni profil korisnika (bez telefona i emaila)                         | Da              |
| PUT   | /api/profile/[id]/update | Izmena sopstvenog profila                                              | Da<br>(vlasnik) |

## 6.5 Admin endpoint-i

Svi `/api/admin/*` endpoint-i zahtevaju `isAdmin=true` u JWT tokenu.

| Metod  | Endpoint                      | Opis                                                                      |
|--------|-------------------------------|---------------------------------------------------------------------------|
| GET    | /api/admin/users              | Lista svih korisnika sa brojem oglasa. Pretraga po email, naziv, PIB      |
| POST   | /api/admin/users              | Kreiranje novog korisnika                                                 |
| GET    | /api/admin/users/[id]         | Detalji korisnika sa dozvolama                                            |
| PUT    | /api/admin/users/[id]         | Izmena korisnika. Ako se verified promeni na true → šalje email odobrenja |
| DELETE | /api/admin/users/[id]         | Brisanje korisnika (cascade delete: dozvole, oglasi, poruke)              |
| POST   | /api/admin/users/[id]/approve | Brzo odobrenje korisnika + slanje emaila odobrenja                        |
| GET    | /api/admin/listings           | Lista svih oglasa sa slikom i firmom                                      |
| POST   | /api/admin/listings           | Kreiranje oglasa u ime druge firme                                        |
| PUT    | /api/admin/listings/[id]      | Izmena bilo kog oglasa                                                    |
| DELETE | /api/admin/listings/[id]      | Brisanje bilo kog oglasa                                                  |
| GET    | /api/admin/notifications      | Lista admin obaveštenja. Query: unread=true za samo nepročitana           |
| PUT    | /api/admin/notifications      | Označavanje kao pročitano. Body: {id} ili {readAll: true}                 |
| POST   | /api/admin/broadcast          | Slanje poruke svim korisnicima (kreira direktne konverzacije)             |

## 7. Frontend Stranice

| Ruta                  | Stranica             | Auth?          | Opis                                                                                                 |
|-----------------------|----------------------|----------------|------------------------------------------------------------------------------------------------------|
| /                     | Početna              | Ne             | Hero sekcija, "kako funkcioniše", tipovi korisnika, CTA                                              |
| /prijava              | Prijava              | Ne             | Email + lozinka. Posebne poruke za neverifikovan email i čekanje odobrenja                           |
| /registracija         | Registracija         | Ne             | 4-koračni wizard: tip → firma → dozvole → kredencijali                                               |
| /verifikacija-emaila  | Email verifikacija   | Ne             | Unos 6-cifrenog koda sa mogućnošću ponovnog slanja                                                   |
| /cekanje-odobrenja    | Čekanje odobrenja    | Ne             | Informativna stranica dok admin pregleda                                                             |
| /zaboravljena-lozinka | Zaboravljena lozinka | Ne             | Unos emaila, šalje reset kod                                                                         |
| /resetuj-lozinku      | Reset lozinke        | Ne             | Unos koda i nove lozinke                                                                             |
| /oglas                | Lista oglasa         | Da             | Grid oglasa sa filterima (kategorija, podkategorija, opština, opasan/neopasan, pretraga), paginacija |
| /oglas/novi           | Novi oglas           | Da (GENERATOR) | Forma sa odabirom kategorije/podkategorije, upload slika, cena/po dogovoru                           |
| /oglas/[id]           | Detalj oglasa        | Da             | Galerija slika, detalji, "Pošalji poruku" dugme, vlasnik može da izmeni/obriše                       |
| /oglas/[id]/izmeni    | Izmena oglasa        | Da (vlasnik)   | Forma sa svim polima unapred popunjena                                                               |
| /korisnici            | Korisnici            | Da             | Lista svih korisnika (bez sopstvenog) sa filterima (grad, tip) i pretragom                           |
| /profil/[id]          | Profil korisnika     | Da             | Podaci firme, lista oglasa (sa edit dugmetom za sopstveni profil), "Pošalji poruku" za tuđe          |
| /podesavanje          | Podešavanja          | Da             | Izmena podataka profila (naziv, adresa, kontakt, bio)                                                |
| /poruke               | Inbox                | Da             | Lista konverzacija sa brojem nepročitanih, osvežava se polling-om svakih 10s                         |
| /poruke/[id]          | Chat                 | Da             | Chat interfejs, polling novih poruka svakih 3s, sanitizovane poruke                                  |
| /uslovi-koriscenja    | Uslovi korišćenja    | Ne             | Pravni dokument                                                                                      |
| /politika-privatnosti | Politika privatnosti | Ne             | GDPR usklađen dokument                                                                               |
| /admin                | Admin dashboard      | Da (admin)     | Statistike, brze akcije                                                                              |
| /admin/korisnici      | Admin korisnici      | Da (admin)     | Tabela sa pretragom, edit/approve/delete                                                             |

|                                  |                   |            |                                                |
|----------------------------------|-------------------|------------|------------------------------------------------|
| <code>/admin/oglas</code>        | Admin oglasi      | Da (admin) | Tabela svih oglasa, edit/delete                |
| <code>/admin/obavestjenja</code> | Admin obaveštenja | Da (admin) | Notifikacije o novim registracijama i oglasima |
| <code>/admin/poruka-svima</code> | Broadcast         | Da (admin) | Slanje poruke svim korisnicima                 |

## 8. Email Sistem

Koristi se **Resend** servis za slanje transakcionih emailova. Resend automatski upravlja SPF, DKIM i DMARC zapisima što garantuje isporučivost na Gmail, Yahoo i ostale provajdere.

### 8.1 Tipovi emailova

| Funkcija                              | Okidač                  | Primalac          | Sadržaj                                   |
|---------------------------------------|-------------------------|-------------------|-------------------------------------------|
| <code>sendVerificationEmail()</code>  | Uspešna registracija    | Novi korisnik     | 6-cifreni verifikacioni kod, važi 15 min  |
| <code>sendPasswordResetEmail()</code> | Zahtev za reset lozinke | Korisnik          | 6-cifreni reset kod, važi 15 min          |
| <code>sendApprovalEmail()</code>      | Admin odobri korisnika  | Odobreni korisnik | Obaveštenje o odobrenju + link za prijavu |

### 8.2 Konfiguracija

```
# .env
RESEND_API_KEY="re_..." # API ključ sa resend.com
RESEND_FROM="Reciklaza.rs <noreply@reciklaza.rs>" # Sender adresa
```

Implementacija se nalazi u `src/lib/email.ts`. Resend klijent se inicijalizuje *lazy* unutar svake funkcije (ne na nivou modula) da bi Next.js build uspešno prošao bez API ključa u build-time okruženju.

## 9. Upload Fajlova

| Tip fajla           | Endpoint                        | Putanja na disku                                  | URL pristup                                           |
|---------------------|---------------------------------|---------------------------------------------------|-------------------------------------------------------|
| Dozvole (PDF/slike) | <code>POST /api/register</code> | <code>public/uploads/permits/{userId}/</code>     | <code>/uploads/permits/{userId}/{filename}</code>     |
| Slike oglasa        | <code>POST /api/upload</code>   | <code>public/uploads/listings/{listingId}/</code> | <code>/uploads/listings/{listingId}/{filename}</code> |

### 9.1 Validacija

| Ograničenje       | Dozvole                                            | Slike oglasa                      |
|-------------------|----------------------------------------------------|-----------------------------------|
| Dozvoljeni tipovi | image/jpeg, image/png, image/webp, application/pdf | image/jpeg, image/png, image/webp |
| Max veličina      | 10 MB po fajlu                                     | 5 MB po slici                     |
| Max broj          | Neograničeno                                       | 8 slika po oglasu                 |

Fajlovi se čuvaju sa slučajnim imenom formata `{timestamp}-{random}.{ext}` da bi se sprečilo pogađanje URL-a i prepisivanje.

**Backup:** Fajlovi se čuvaju lokalno na VPS-u. Preporučuje se periodični backup foldera `/var/www/recikla.rs/public/uploads/` na eksterni storage.

## 10. Admin Panel

Admin panel je dostupan na `https://reciklaza.rs/admin` isključivo za korisnike sa `isAdmin=true` flagom. Pristup se štiti i na nivou middleware-a i na nivou svakog API endpoint-a.

### 10.1 Funkcionalnosti admin panela

#### Upravljanje korisnicima

- Pregled svih registrovanih korisnika
- Odobrenje/odbijanje novih korisnika
- Izmena svih podataka korisnika
- Kreiranje korisnika direktno (bez email verifikacije)
- Brisanje korisnika (cascade)

#### Upravljanje oglasima

- Pregled svih oglasa sa pretragom
- Izmena bilo kog oglasa (sve stavke)
- Promena statusa oglasa
- Kreiranje oglasa u ime bilo koje firme
- Brisanje oglasa

#### Obaveštenja

- Automatska notifikacija pri novoj registraciji
- Automatska notifikacija pri novom oglasu
- Crveni badge sa brojem nepročitanih u sidebar-u
- Direktan link do korisnika/oglasa

#### Broadcast poruke

- Slanje poruke svim korisnicima odjednom
- Poruke stižu kao direktne poruke u inbox
- Potvrda sa brojem primalaca

### 10.2 Admin nalog

Admin nalog se kreira putem seed skripte. Da bi korisnik bio admin, polje `isAdmin` mora biti `true` u bazi. Ovo se ne može postaviti putem registracionog interfejsa — isključivo direktno u bazi ili putem seed skripte.

# 11. Bezbednost

| #  | Mera                               | Implementacija                                                                                                                       |
|----|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| 1  | <b>Zaštita ruta (Middleware)</b>   | NextAuth <code>authorized()</code> callback u <code>src/middleware.ts</code> proverava JWT token i preusmerava neovlašćene korisnike |
| 2  | <b>Security Headers</b>            | X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy konfigurisani u <code>next.config.ts</code>             |
| 3  | <b>Rate Limiting</b>               | In-memory implementacija u <code>src/lib/rate-limit.ts</code> . Limiti: auth 5/min, API 30/min, upload 10/min, poruke 20/min         |
| 4  | <b>Input Validacija (Zod)</b>      | Sve forme i API endpoint-i validiraju input na klijentu (UX) i serveru (bezbednost)                                                  |
| 5  | <b>SQL Injection zaštita</b>       | Prisma koristi parametrizovane upite — direktno SQL ubacivanje je nemoguće                                                           |
| 6  | <b>Input Sanitizacija</b>          | <code>src/lib/utills/sanitize.ts</code> uklanja HTML tagove, JavaScript protokol i event handler-e iz korisničkog unosa              |
| 7  | <b>Upload Validacija</b>           | Provera MIME tipa, veličine fajla i broja fajlova pre čuvanja                                                                        |
| 8  | <b>Hashovanje lozinki</b>          | bcrypt sa salt rounds 12 — nemoguće dešifrovati u razumnom vremenu                                                                   |
| 9  | <b>CSRF zaštita</b>                | NextAuth automatski generiše CSRF token za sve POST/PUT/DELETE zahteve                                                               |
| 10 | <b>Privatnost kontakt podataka</b> | Telefon i email se NIKADA ne prikazuju javno — komunikacija isključivo kroz platformu                                                |
| 11 | <b>HTTPS</b>                       | SSL/TLS putem Let's Encrypt (auto-renew), HTTP → HTTPS redirect u Nginx-u                                                            |
| 12 | <b>Firewall (UFW)</b>              | Na VPS-u otvoreni samo portovi 22 (SSH), 80 (HTTP→redirect), 443 (HTTPS), 8080 (phpMyAdmin)                                          |
| 13 | <b>Autorizacija na API-ju</b>      | Svaki endpoint proverava sesiju korisnika. Admin endpoint-i dodatno proveravaju <code>isAdmin</code> flag                            |
| 14 | <b>Honeypot (Anti-spam)</b>        | Skriveno polje u kontakt formi koje boti popunjavaju — ako je popunjeno, zahtev se tiho ignoriše                                     |

## 12. Deployment i Infrastruktura

### 12.1 Serverska konfiguracija

| Komponenta        | Detalji                                           |
|-------------------|---------------------------------------------------|
| VPS provajder     | Hostinger KVM                                     |
| Operativni sistem | Ubuntu 22.04 LTS                                  |
| IP adresa         | 152.239.119.45                                    |
| Hostname          | srv1794962.hstgr.cloud                            |
| Node.js           | v20.20.2 (LTS)                                    |
| MySQL             | 8.x, korisnik: reciklaza_app (samo LOCAL pristup) |
| Nginx             | 1.18 — reverse proxy na localhost:3000            |
| PM2               | 7.x — process manager, boot startup               |
| Certbot           | Let's Encrypt, automatski renew, ističe 90 dana   |

### 12.2 Nginx konfiguracija

```
# /etc/nginx/sites-enabled/reciklaza.rs
server {
    listen 80;
    server_name reciklaza.rs www.reciklaza.rs;
    return 301 https://$host$request_uri; # HTTP → HTTPS redirect
}

server {
    listen 443 ssl;
    server_name reciklaza.rs www.reciklaza.rs;
    client_max_body_size 15M;

    ssl_certificate /etc/letsencrypt/live/reciklaza.rs/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/reciklaza.rs/privkey.pem;

    location / {
        proxy_pass http://localhost:3000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

## 12.3 PM2 upravljanje

```
# Pokretanje
pm2 start npm --name reciklaza -- start
pm2 save # Čuvanje za auto-start pri reboot-u
pm2 startup systemd # Konfiguracija systemd servisa

# Upravljanje
pm2 status # Status procesa
pm2 logs reciklaza # Live logovi
pm2 logs reciklaza --lines 100 # Posled 100 linija logova
pm2 restart reciklaza # Restart (bez reload .env)
pm2 stop reciklaza && pm2 delete reciklaza # Potpuni stop
```

## 12.4 Proces deploy-a (ažuriranja)

Pri svakoj novoj verziji koda pokreće se deploy skripta `/root/deploy.sh`:

```
ssh root@152.239.119.45 "/root/deploy.sh"
```

Skripta automatski:

1. Povlači izmene sa GitHub repozitorijuma ( `git pull origin main` )
2. Instalira nove zavisnosti ( `npm install` )
3. Primenjuje izmene šeme baze ( `npx prisma db push` )
4. Pravi production build ( `npm run build` )
5. Restartuje aplikaciju sa novim `.env` varijablama

**Napomena o .env:** Fajl `.env` se NE čuva u git repozitorijumu. Sve izmene env varijabli na serveru se rade direktno: `ssh root@152.239.119.45 "nano /var/www/reciklaza-rs/.env"`, nakon čega je potrebno pokrenuti deploy skriptu.

## 13. Konfiguracija Okruženja

Sve env varijable nalaze se u fajlu `.env` u root direktorijumu projekta. Primer `.env.example` je dostupan u repozitorijumu.

| Varijabla                    | Opis                                              | Primer                                                              |
|------------------------------|---------------------------------------------------|---------------------------------------------------------------------|
| <code>DATABASE_URL</code>    | MySQL connection string                           | <code>mysql://reciklaza_app:lozinka@localhost:3306/reciklaza</code> |
| <code>AUTH_SECRET</code>     | Tajni ključ za JWT (min 32 karaktera, random)     | <code>openssl rand -base64 32</code>                                |
| <code>AUTH_URL</code>        | URL aplikacije (mora biti HTTPS na produkciji)    | <code>https://reciklaza.rs</code>                                   |
| <code>AUTH_TRUST_HOST</code> | Dozvoljava NextAuth-u da veruje proxy headerima   | <code>true</code>                                                   |
| <code>RESEND_API_KEY</code>  | Resend API ključ za slanje emailova               | <code>re_xxxxxxxxxxxx</code>                                        |
| <code>RESEND_FROM</code>     | Sender adresa (mora biti sa verifikovanog domena) | <code>Reciklaza.rs &lt;noreply@reciklaza.rs&gt;</code>              |
| <code>MAX_FILE_SIZE</code>   | Max veličina upload-a u bajtovima                 | <code>5242880</code> (5MB)                                          |

## 14. Lokalni Razvoj

### 14.1 Preduslovi

- Node.js 20+ (LTS)
- MySQL 8.x ili MariaDB (lokalno, XAMPP, Docker itd.)
- Git

## 14.2 Pokretanje

```
# 1. Kloniranje repozitorijuma
git clone https://github.com/mdjordjevic97/reciklaza-rs.git
cd reciklaza-rs

# 2. Instalacija zavisnosti
npm install

# 3. Kreiranje .env fajla
cp .env.example .env
# Uredi .env i popuni DATABASE_URL, AUTH_SECRET, RESEND_API_KEY

# 4. Kreiranje baze i tabela
npx prisma db push

# 5. Popunjavanje testnim podacima (opcionarno)
npx tsx prisma/seed.ts

# 6. Pokretanje development servera
npm run dev
# → http://localhost:3000
```

## 14.3 Test nalozi (posle seed-a)

| Email                | Lozinka  | Tip       | Status           |
|----------------------|----------|-----------|------------------|
| admin@reciklaza.rs   | admin123 | Admin     | ✓ Aktivan        |
| ekoreciklaza@test.rs | test1234 | Sakupljač | ✓ Aktivan        |
| metalservis@test.rs  | test1234 | Sakupljač | ✓ Aktivan        |
| gradnja@test.rs      | test1234 | Generator | ✓ Aktivan        |
| fabrika@test.rs      | test1234 | Generator | ✓ Aktivan        |
| hemind@test.rs       | test1234 | Generator | ⌚ Čeka odobrenje |
| zeleniput@test.rs    | test1234 | Sakupljač | ✓ Aktivan        |

## 14.4 Korisne komande

```
# Prisma Studio - GUI za bazu
npx prisma studio

# Prisma generate (regenerisanje klijenta posle izmene šeme)
npx prisma generate

# Production build
npm run build

# Pokretanje production build-a lokalno
npm start

# Lint
npm run lint
```

## 14.5 GitHub repozitorijum

Kod je dostupan na privatnom GitHub repozitorijumu: [github.com/mdjordjevic97/reciklaza-rs](https://github.com/mdjordjevic97/reciklaza-rs)

Main branch: [main](#) — direktno se deplojuje na produkciju putem deploy skripte.

---

### Reciklaža.rs — Tehnička Dokumentacija v1.0

PORT 22 Mihailo Đorđević PR · PIB: 111988991 · MB: 65790777

Dokument je poverljiv i namijenjen isključivo tehničkom osoblju.